❶ 첫 공격 막은 우리銀 … AI 해킹, 24시간 감시 AI 방패로 차단



4일 서울시내 주요 은행 현금자동입출금기에 고객들이 몰려 있다. 김재훈 기자

금융권 AI 해킹 현황

*자료=금융권

1금융권	신한은행	2만5000명
	국민은행	119명
	하나은행	89명
	부산은행	11건
	우리·농협은행	공격 시도 확인·차단
2금융권	예가람저축은행	4만명
	웰컴저축은행	2200건
	현대캐피탈	146명
	PFCT(온투업)	304명
	농협·새마을금고	공격 시도 확인·차단



금융권 동시해킹 3대 쟁점

5대 은행과 지방은행에 이어 캐피탈·상호금융·저축은행·온투업등 제2금융권에서도 동시다발로 인공지능(AI)을 활용한 해킹 공격 정황이 드러나면서 금융권 정보 유출에 대한 경계심이 커지고 있다. 상당수 금융사가 공격 사실을 뒤늦게 인지한 것으로 나타나 추가 피해 사례도 속속 보고되고 있다. 금융당국은 4일 전 금융권을 긴급 소집했다. 이번 사태를 둘러싼 핵심 의문과 대응책을 짚어봤다.

AI를 활용한 해킹 가능성은 이미 수차례 경고돼왔다. 망분리 정책만으로는 해킹을 피할 수 없다는 지적이었다. 금융당국은 올해 5월 고성능 AI가 기존 방식으로는 찾기 어려운 취약점을 빠르게 탐색할 수 있다며 보안 목적 AI 활용을 위한 망분리 규제 긴급 완화에 나서기도 했다. 그럼에도 금융권 대응이 AI 발달 속도를 따라가지 못했다는 지적이 나온다. 금융권 정보기술(IT) 시스템이 수십 년간 구축한 기존 전산망에 모바일·응용프로그래밍인터페이스(API)·외부 제휴 서비스 등을 계속 덧붙이는 방식으로 확장돼온 점도 취약 요인으로 꼽힌다. 일각에서는 금융권의 AI 보안 도구 도입을 제약해온 망분리 규제 개선이 더 빨랐어야 했다는 지적도 나온다.

금융당국 점검에서는 금융사 시스템 허점도 발견됐다. 개인정보가 유출된 일부 은행의 정보조회 서비스는 휴대전화 인증 등 본인확인 절차 없이 대출신청내역과 기업대표정보 등을 조회할 수 있도록 잘못 설계돼 있었고,

❷ AI 해킹 우려 쏟아졌지만 업무망, 상대적 보안 취약

❸ 中 서비스 이용 흔적 발견 국적 단정 단계 아직 아냐

당국 "보안 탐지체계 재점검"

직원용 업무지원 서비스는 외부 접속 통제와 인증 절차가 미흡해 허가받지 않은 앱이 등록될 수 있는 구조였다.

이번 공격의 특징은 인터넷·모바일 뱅킹 같은 대고객 핵심 채널보다 상대적으로 이용자가 적은 외곽 시스템에 집중됐다는 점이다. 신한은행 대출모집인 전용 서비스, KB국민은행의 직원용 모바일 업무지원 시스템, 하나은행의 영업지원시스템(ODS) 등이 대표적이다. 일례로 신한은행 대출모집인 전용 서비스에서는 민감한 정보 조회 단계에서 공동인증서나 OTP 등 별도의 추가 인증 수단을 요구하는 다중요소인증(MFA) 체계가 적용되지 않았던 것으로 파악됐다.

핵심 뱅킹 서비스는 상시 모니터링과 보안 투자가 집중되는 반면 업무지원 채널은 상대적으로 감시나 패치 주기가 느슨할 수 있다는 게 보안 전문가들의 설명이다.

공격을 막아낸 사례도 주목된다. 우리은행과 NH농협은행은 공격 시도를 받았지만 현재까지 정보 유출은 확인되지 않았다. 우리은행 모회사 우리금융은 클로드를 활용한 사이버 보안 솔루션 '진트'를 도입해 상시 모의 해킹을 실시하며 취약점을 발견하고 선제적으로 보완했다. 진트가 한 달간 발견해내는 보안 취약점은 인간 화이트해커가 반년 동안 찾아내는 양과 비슷한 수준으로 알려졌다. 향후 금융권에서는 AI에 맞서 AI로 취약점을 먼저 탐지하는 방어 방식이 빠르게 확산할 것으로 보인다.

공격자 정체는 아직 확정되지 않았다. 다만 여러 금융회사가 짧은 기간 비슷한 방식으로 공격받았고, 일부 공격에 사용된 IP가 일치한 것으로 파악되면서 금융당국에서는 동일 공격자 또는 연계된 공격 세력일 가능성에 무게를 두고 있다. 신한·국민은행 공격에 사용된 IP 일부가 일치한 사실도 관계당국 조사 과정에서 알려졌다.

일각에서는 최근 글로벌 사이버 공격에서 활동 반경을 넓히고 있는 중국·북한계 해커의 소행일 가능성을 의심하고 있다. 신한은행을 공격한 것으로 추정되는 서버에서는 중국어로 'AI 자율 침투 테스트 콘솔'을 뜻하는 문자열과 오픈소스 자율형 침투 테스트 도구 'ARTEX AI' 관련 흔적이 확인되기도 했다. 다만 아직 조사 초기 단계이며, IP는 언제든 우회가 가능하기 때문에 금융당국 조사보다 경찰 수사 단계에서 밝혀질 전망이다.

금융당국은 이날 '전 금융권 긴급 점검회의'를 열어 향후 AI 에이전트가 다수 기관을 대상으로 짧은 기간에 대량의 자동화 공격을 수행할 수 있을 것으로 판단하고 대응책을 주문했다.

박창영·연규욱·오찬종 기자